

Lab 3: Multi-Jurisdiction Compliance Challenge

Company: KigaliMart (Rwandan cross-border e-commerce platform)

Scenario: Customer data-rights requests from three different legal jurisdictions, received in the same week

Regulations in scope: Rwanda's Law N° 058/2021 relating to the Protection of Personal Data and Privacy ("the Rwanda Data Protection Law"); the EU General Data Protection Regulation (GDPR); the California Consumer Privacy Act as amended by the CPRA (CCPA/CPRA)

Status: Required Lab

***Note on legal accuracy:** This lab is a training exercise, not legal advice. Deadlines and penalty figures for Rwanda's Law N° 058/2021 are presented at the level of general principle (consistent with how Rwanda's National Cyber Security Authority, the Law's supervisory authority, describes them publicly) rather than exact article-by-article citation, and should be confirmed against the current text of the Law and any implementing regulations before being relied on operationally.*

1. Scenario

KigaliMart sells Rwandan-made crafts, coffee, and fashion internationally. It has three open data-subject requests this week:

- **Customer A — Uwase** (Kigali, Rwanda): a Rwandan resident.
- **Customer B — Klaus** (Berlin, Germany): an EU resident, governed by GDPR.
- **Customer C — Jennifer** (Los Angeles, California, USA): a California resident, governed by CCPA/CPRA.

Each has asked KigaliMart to delete their account. Each request must be resolved under the law that applies to *that customer*, not under whichever law is most convenient for KigaliMart — this is the core challenge of operating across jurisdictions.

2. Customer A – Uwase (Rwanda)

Legal Rights Analysis

- Under Rwanda's Law N° 058/2021, data subjects have rights of access, rectification, objection, and erasure over personal data held about them, exercised against the data controller (KigaliMart). Like most modern data protection regimes, this right is **not absolute** — it yields to the controller's other legal obligations.

Company Obligations

- Assess the request against any Rwandan legal retention obligation (tax law, consumer-protection law, anti-money-laundering rules if payment records are involved) before deleting.
- Delete personal data for which no such obligation exists.
- Log the request and the decision for audit purposes, since the Law's accountability principle expects controllers to be able to demonstrate compliance, not merely claim it.

Data Retention

- **Can retain:** Transaction and payment records required for Rwandan tax and financial record-keeping.
- **Retention period:** Set by the applicable tax/financial regulations rather than the data protection law itself — typically several years; confirm the current statutory period with Rwanda Revenue Authority guidance before finalizing a retention schedule.

Response Deadline

- The Law does not fix a universal numeric deadline in the way GDPR does; the operating norm is to respond **without undue delay** and within a **reasonable time** — many controllers align this internally to **30 days** as a defensible default consistent with regional and GDPR-influenced practice, even though Rwandan law itself does not mandate that exact figure.

Action Steps

1. Verify Uwase's identity (matching account details against the request channel).
2. Identify and delete personal/profile data with no retention basis.
3. Retain only the specific records required by tax/financial regulation, clearly tagged with the legal basis for retention.
4. Log the request, decision, and retained-data justification.
5. Confirm completion to Uwase in writing.

Draft Response

"Dear Uwase, we have received and processed your request. Your personal account data has been deleted, with the exception of transaction records we are required to retain under Rwandan tax and financial regulations. Thank you for being a KigaliMart customer."

3. Customer B – Klaus (Germany – GDPR)

Legal Rights Analysis

- Klaus has a strong, explicit **right to erasure ("right to be forgotten")** under GDPR Article 17, one of the most litigated and clearly defined rights in any of the three regimes considered here.

Exemptions

- Data may be retained where necessary for:
- Compliance with a legal obligation (e.g., EU/German tax law),
- Establishment, exercise, or defense of legal claims.

Company Obligations

- Delete personal data **without undue delay**, and in any event within the statutory window (see deadline below).
- Notify any third-party processors who received the data (e.g., a shipping partner or payment processor) that erasure has been requested, per Article 19.
- Because KigaliMart is a Rwandan controller serving an EU resident, GDPR's extraterritorial scope (Article 3(2)) applies to this relationship regardless of where KigaliMart is based.

Response Deadline

- **One month (30 days)** from receipt of the request, extendable by two further months for complex requests with notice to the data subject.

Penalties for Missing the Deadline

- Fines of up to **€20 million or 4% of global annual turnover**, whichever is higher — materially higher exposure than either of the other two regimes in this scenario.

Action Steps

1. Verify Klaus's identity.
2. Delete personal data across all systems, including backups where feasible.
3. Notify third-party processors that erasure has occurred.
4. Confirm deletion to Klaus in writing, referencing GDPR Article 17.

Draft Response

"Dear Klaus, we confirm that your personal data has been erased in accordance with Article 17 of the GDPR. Any records we are legally required to retain have been securely preserved as permitted by law, and all third parties who processed your data on our behalf have been notified of your erasure request."

4. Customer C – Jennifer (California – CCPA/CPRA)

Legal Rights Analysis

Jennifer has two distinct rights that must be handled separately:

- **Right to deletion** of personal information collected by KigaliMart.
- **Right to opt out** of the sale/sharing of her personal information — a right the CCPA treats as urgent and separate from deletion, and which must be honored **immediately**, independent of whatever happens with the deletion request.

Can Deletion Be Immediate?

- **No** — Jennifer has an active return dispute open on a recent order. Order and dispute-related data must be retained temporarily to resolve it; deleting it mid-dispute would itself create a compliance and customer-service problem.

Company Obligations

- Pause the deletion until the dispute resolves.
- Immediately implement the "Do Not Sell or Share My Personal Information" opt-out, regardless of the deletion pause.

Response Deadline

- **45 days**, extendable to **90 days** with notice to the consumer explaining the reason for the extension.

Required Disclosures

- What categories of personal information were collected.
- How that information has been used and with whom it has been shared.
- Confirmation that the opt-out request has been implemented.

Action Steps

1. Verify Jennifer's identity.
2. Implement the sale/sharing opt-out immediately.
3. Inform Jennifer that full deletion will proceed once the return dispute is resolved, and give an expected timeframe.
4. Complete deletion once the dispute closes; confirm in writing.

Draft Response

"Dear Jennifer, we have implemented your request to stop the sale or sharing of your personal information, effective immediately. Your deletion request will be completed once your active return dispute is resolved, as permitted under the CCPA/CPRA. We collect your name, contact details, and order history to fulfil and support your orders, and share limited data with our shipping and payment partners as needed."

5. Compliance Comparison Table

Element	Rwanda Law N° 058/2021	GDPR	CCPA/CPRA
Right to deletion exists?	Yes (qualified)	Yes (strong, explicit)	Yes
Separate sale/sharing opt-out right?	Not a distinct statutory right in the same form	No separate "sale" concept as such	Yes — a core, urgent right
Exemptions / conditions	Legal obligations, ongoing contractual necessity	Legal compliance, defense of legal claims	Ongoing transactions/disputes, legal obligations
Response deadline	No fixed statutory number; "reasonable time," commonly operationalized as ~30 days	30 days (extendable to 90 with notice)	45 days (extendable to 90 with notice)
Supervisory authority	National Cyber Security Authority (NCSA)	National/EU Data Protection Authorities	California Privacy Protection Agency (CPPA)
Penalties for non-compliance	Administrative sanctions, with escalation to criminal liability possible for serious breaches (confirm current amounts with counsel)	Up to €20M or 4% of global annual turnover	Fines per violation (statutory amounts periodically adjusted)
Cross-border relevance to KigaliMart	Home jurisdiction — baseline obligations always apply	Applies extraterritorially to any Rwandan controller serving EU residents	Applies extraterritorially to any Rwandan controller serving California residents meeting CCPA's thresholds

6. Key Insights

- **GDPR carries the clearest process and the highest financial exposure** of the three — a fixed 30-day clock and fines calculated as a percentage of *global* turnover mean a GDPR miss is the most expensive mistake KigaliMart could make in this scenario, even though it is a Rwandan company.
- **CCPA/CPRA's distinguishing feature is the opt-out right**, which is independent of and faster than the deletion right — a common mistake is treating "delete my data" and "stop selling my data" as the same request when California law treats them as two different obligations with two different clocks.
- **Rwanda's Law N° 058/2021 gives KigaliMart the most operational flexibility as the home-jurisdiction regime**, but "flexible" is not the same as "optional" — the NCSA can still act on non-compliance, and treating the home-market request more casually than the foreign ones is a reputational risk even where it may not be the strictest legal risk.
- **Being a Rwandan company does not shield KigaliMart from GDPR or CCPA.** Once it knowingly serves EU or California residents, it has stepped into the extraterritorial scope of both regimes and must be able to run three different compliance clocks simultaneously — which argues for building one data-subject-request workflow that is parameterized by jurisdiction rather than three separate ad hoc processes.

7. Conclusion

KigaliMart's three requests look identical on the surface — "delete my data" — but resolve completely differently depending on which law governs the customer. Rwanda's own law gives the company room to align its response time to its resource capacity; GDPR gives Klaus a hard 30-day clock and no such flexibility; and CCPA/CPRA gives Jennifer a right (opt-out) that has nothing to do with deletion at all and must be actioned instantly regardless of an open dispute. Handling all three correctly requires KigaliMart to identify jurisdiction *before* deciding how to respond — a single company-wide "we respond to deletion requests within 30 days" policy would be silently non-compliant for the fraction of requests that are actually governed by CCPA/CPRA's separate opt-out clock or GDPR's stricter extension rules. Building a jurisdiction-aware intake process is therefore not a nice-to-have; it is the only way a single global privacy policy can be true in every market at once.